

APT33 — Peach Sandstorm

Threat Actor Profile | Aviation & Aerospace

Published: 2026-05-29 | Profile ID: LBC-AP-2026-003 | TLP: AMBER

Prepared by: Lost Boys Cyber — Threat Intelligence Team

AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

This profile was generated with AI assistance. All TTPs, IOCs, attribution assessments, and detection rules must be independently validated by a qualified analyst before operational use, external distribution, or legal/regulatory action.

Attribution Warning: Nation-state attribution is probabilistic. Confidence levels reflect analytical assessment only — not proof.

1. At a Glance

Attribute	Value
Primary Alias	APT33
MITRE ATT&CK Group	G0064 — https://attack.mitre.org/groups/G0064/
Nation-State Sponsor	Iran — Islamic Revolutionary Guard Corps (IRGC)
Motivation	Espionage: aviation/aerospace IP theft; sabotage capability (SHAPESHIFT wiper)
Active Since	2013 (confirmed)
Activity Status	Active
Sophistication	Advanced — nation-state
Primary Sectors	Aviation, Aerospace, Satellite, Energy, Petrochemical, Defence
Primary Geographies	United States, Saudi Arabia, South Korea, Middle East (UAE, Israel), Australia
Assessment Confidence	High — multiple independent vendor corroboration + official attribution

2. Identity & Aliases

Vendor	Designation
Microsoft	Peach Sandstorm (formerly HOLMIUM)
Symantec / Broadcom	Elfin
CrowdStrike	Refined Kitten
Mandiant / Google	APT33
FireEye	APT33
Recorded Future	COBALT TRINITY
MITRE ATT&CK	G0064
CISA	APT33 / Peach Sandstorm (joint advisories)

3. Attribution Assessment

Assessment: Iran — IRGC-directed espionage and sabotage capability.

Confidence: High

APT33 is assessed with high confidence as an Iranian state-sponsored group operating under IRGC direction, based on: targeting alignment with Iranian strategic interests (aviation/aerospace IP that could accelerate domestic programmes), use of IRGC-linked infrastructure, working hours consistent with Iranian time zones, and independent corroboration from Mandiant, Symantec, Microsoft, and CISA in joint advisories.

The group's dual-use mandate — combining espionage with SHAPESHIFT wiper capability linked to the Shamoon/DistTrack ecosystem — mirrors the IRGC's established pattern of maintaining sabotage options within intelligence-collection operations.

Evidence Type	Detail	Confidence
Targeting alignment	Aviation, aerospace, satellite, energy — all align with Iranian strategic development priorities	High
Working hours	Activity clustered in UTC+3:30/+4:30 windows consistent with Iranian business hours	Medium
Infrastructure	IRGC-linked hosting; recurring use of Iranian-registered domains	Medium
Wiper overlap	DROPSHOT delivers SHAPESHIFT; only APT33 observed using DROPSHOT; links to Shamoon ecosystem	High
CISA/vendor attribution	Named in multiple official US government and allied-nation advisories	High
Alternative hypothesis	False flag by another actor using Iranian infrastructure — assessed unlikely given operational consistency across 10+ years	N/A

4. Background & History

APT33 has maintained a singular, persistent focus on aviation and aerospace since at least 2013 — longer than any other actor on this list. The group targets organisations whose IP could accelerate Iran's domestic air force, ballistic missile programme, or satellite capability. A defining feature is the dual-use mandate: networks compromised for intelligence collection could be repurposed for destructive operations at the Iranian government's discretion.

In 2023–2024, APT33/Peach Sandstorm dramatically escalated password spray activity, targeting O365 and Azure AD accounts across US and Australian defence, space, education, and government organisations. Microsoft Threat Intelligence documented a surge beginning February 2023 and peaking April–July 2024. The group used Azure infrastructure for staging, blending C2 traffic with legitimate cloud usage.

Date	Event	Significance
2013	First observed activity	Earliest attributed intrusions; Saudi petrochemical and aviation targeting
2017	FireEye public disclosure	First major public report; aviation and energy targeting confirmed
2018	SHAPESHIFT deployment	Wiper deployed in destructive operations; dual-use capability confirmed
Feb 2023	Password spray campaign begins	Mass credential spraying against US/Australian defence/space orgs via Azure
Apr–Jul 2024	Escalated spray activity	Microsoft TI: Peach Sandstorm targets defence, space, education, government
2024–2026	Ongoing elevated tempo	Continued Western aerospace supply chain targeting; improved evasion

5. Objectives & Targeting

APT33 targets organisations that hold intellectual property directly applicable to Iranian military aviation and aerospace development: aircraft manufacturers, defence prime contractors, satellite operators, aviation research institutions, and suppliers to these organisations. Secondary targeting includes energy and petrochemical firms. The group employs both mass credential spraying (broad initial access) and precision spearphishing (high-value individual targeting).

Attribute	Detail
Organisation Size	Large enterprise and government — defence primes and aerospace OEMs are primary
Technology Environment	Windows-centric; O365/Azure AD; Exchange on-premises
Specific Technologies Targeted	O365, Azure AD, Exchange — primary credential spray targets
Access Brokers Used	No — conducts own initial access operations
Supply Chain Interest	Secondary — targeting suppliers to reach primary defence primes

6. TTPs — MITRE ATT&CK

Tactic	Technique	Observed	Frequency	Notes
Reconnaissance	T1595.001 — IP Scanning	Yes	Med	Pre-compromise scanning of target infrastructure
Resource Dev	T1583.001 — Domains	Yes	High	Typosquatted domains mimicking aerospace firms
Initial Access	T1566.001 — Spearphishing Attachment	Yes	High	Job-themed .hta lures delivering TURNEDUP
Initial Access	T1078 — Password Spraying	Yes	High	Mass O365/Azure AD spray — primary 2023–2024 vector
Execution	T1218.005 — Mshta	Yes	High	.hta execution delivers TURNEDUP backdoor
Execution	T1059.001 — PowerShell	Yes	High	POWERTON; post-exploitation scripting
Persistence	T1053.005 — Scheduled Task	Yes	Med	Post-compromise persistence
Persistence	T1547.001 — Registry Run Keys	Yes	Med	Additional persistence for POWERTON
Defence Evasion	T1027 — Obfuscated Files	Yes	High	Encoded PowerShell; packed payloads
Defence Evasion	T1078.004 — Cloud Accounts	Yes	High	Azure-hosted C2; blends with enterprise traffic
Credential Access	T1110.003 — Password Spraying	Yes	High	Primary initial access vector 2023–2024
Credential Access	T1003 — Credential Dumping	Yes	Med	Mimikatz, LaZagne post-compromise
Collection	T1114.002 — Remote Email Collection	Yes	High	O365 mailbox access post-spray

C2	T1071.001 — Web Protocols	Yes	High	Custom HTTPS C2; Azure-hosted infrastructure
Impact	T1485 — Data Destruction	Suspected	Low	SHAPESHIFT wiper; destructive capability confirmed

7. Toolset

Tool	Type	Purpose	Attribution Confidence
TURNEDUP	Backdoor	Primary C++ RAT; full remote access; delivered via .hta lures	High — exclusive to APT33
DROPSHOT	Dropper	Self-deleting dropper delivering SHAPESHIFT; unique artefact	High — exclusive to APT33
SHAPESHIFT	Wiper	Destructive disk wiper; Shamoon/DistTrack ecosystem	High
POWERTON	PS Backdoor	PowerShell second-stage backdoor; C2 via cloud services	High
NanoCore RAT	Commodity RAT	Remote access; publicly available	Medium
NetWire RC	Commodity RAT	Remote access and keylogging	Medium
Mimikatz / LaZagne	Credential tools	Post-compromise credential harvesting	Low — commodity
PupyRAT	Open-source RAT	Cross-platform remote access	Medium

8. Infrastructure Profile

Attribute	Observed Pattern
Domain Registrar	Mix of Iranian registrars and privacy-proxied international registrars
Domain Naming	Typosquatting of aerospace brands;

	job/recruitment themed domains
Hosting	Azure cloud infrastructure for C2 (2023–2024); some IRGC-adjacent hosting
Certificate Use	Valid TLS certificates to blend C2 traffic
Infrastructure Rotation	Moderate — rotate per campaign; spray infrastructure changes frequently
Notable Domains (historical)	Aviation/aerospace brand impersonation; see Unit42/Mandiant IOC feeds for current list

9. Detection

9.1 Sigma — Password Spray vs O365

```
title: APT33/Peach Sandstorm — O365 Password Spray Detection
id: a1f2e3d4-b5c6-7890-abcd-ef1234560001
status: experimental
description: Spike of authentication failures from single IP consistent with APT33 password spray
references:
  - https://attack.mitre.org/groups/G0064/
author: Lost Boys Cyber | date: 2026-05-29
tags:
  - attack.credential_access
  - attack.t1110.003
logsource:
  product: azure
  service: signinlogs
detection:
  selection:
    ResultType: "50126"
  timeframe: 10m
  condition: selection | count() by IPAddress > 20
falsepositives:
  - Misconfigured legacy auth clients
level: high
```

9.2 Sigma — Mshta .hta Lure Execution

```
title: APT33 — TURNEDUP Delivery via Mshta Executing Remote .hta
id: a2f3e4d5-b6c7-8901-bcde-f23456780002
status: experimental
description: mshta.exe executing a remote .hta URL — primary TURNEDUP delivery method
tags:
  - attack.execution
  - attack.t1218.005
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    Image|endswith: "\mshta.exe"
    CommandLine|contains:
      - "http://"
      - "https://"
```

```

- ".hta"
filter:
  CommandLine|contains: "C:\Windows"
condition: selection and not filter
falsepositives:
- Legacy enterprise web applications using mshta
level: high

```

9.3 KQL — O365 Mailbox Delegation Post-Spray

```

// APT33: Post-spray mailbox access – detect delegated mailbox rules added from
unusual IP
OfficeActivity
| where TimeGenerated > ago(30d)
| where Operation in ("Add-MailboxPermission", "Add-RecipientPermission", "Set-
Mailbox")
| where ClientIP !startswith "10." and ClientIP !startswith "192.168."
| project TimeGenerated, UserId, Operation, ClientIP, Parameters
| order by TimeGenerated desc

```

9.4 YARA — TURNEDUP Backdoor

```

rule APT33_TURNEDUP_Backdoor {
  meta:
    description = "Detects APT33 TURNEDUP backdoor characteristics"
    author      = "Lost Boys Cyber"
    date        = "2026-05-29"
    reference    = "https://attack.mitre.org/groups/G0064/"
    actor       = "APT33 / Peach Sandstorm"
  strings:
    $mz = { 4D 5A }
    $s1 = "TURNEDUP" ascii wide nocase
    $s2 = "powerton" ascii wide nocase
    $s3 = "CurrentVersion\Run" ascii wide
    $s4 = "mshta.exe" ascii wide
    $hta = ".hta" ascii wide
  condition:
    $mz at 0 and filesize < 10MB and
    (($s1 or $s2) or ($s3 and $hta and $s4))
}

```

10. Threat Hunting

10.1 Hunt: Azure AD Spray from Single Source

Hypothesis: If APT33 has targeted this organisation via password spray, failed authentication events will cluster by source IP against multiple accounts within short time windows.

```

// Azure AD – password spray detection
SigninLogs
| where TimeGenerated > ago(90d)
| where ResultType == "50126"
| summarize FailedAttempts=count(), UniqueAccounts=dcount(UserPrincipalName)
  by IPAddress, bin(TimeGenerated, 10m)
| where UniqueAccounts > 10
| order by FailedAttempts desc

```


10.2 Hunt: Mshta Child Process Ancestry

Hypothesis: TURNEDUP delivery via mshta.exe will show mshta executing as a child of a document viewer or email client, followed by network callback.

```
DeviceProcessEvents
| where Timestamp > ago(90d)
| where FileName =~ "mshta.exe"
| where InitiatingProcessFileName in~
("winword.exe", "outlook.exe", "excel.exe", "acrord32.exe")
| project Timestamp, DeviceName, AccountName, ProcessCommandLine,
InitiatingProcessFileName
| order by Timestamp desc
```

10.3 Hunt: O365 Access from New Country post-Spray

Hypothesis: Post-spray, APT33 accesses mailboxes from Iranian or VPN-proxied IPs not previously seen for that account.

```
SigninLogs
| where TimeGenerated > ago(30d)
| where ResultType == "0"
| summarize Countries=make_set(Location), LastSeen=max(TimeGenerated)
  by UserPrincipalName
| where array_length(Countries) > 3
| order by LastSeen desc
```

11. Recommended Defensive Posture

Priority Hardening

- Enforce phishing-resistant MFA (FIDO2/hardware key) on all O365/Azure AD accounts — defeats password spraying, APT33's dominant 2023–2025 initial access vector.
- Enable Azure AD Identity Protection and configure Conditional Access to block "high risk" sign-ins automatically.
- Block mshta.exe via ASR rules or application control — TURNEDUP is delivered almost exclusively through mshta/.hta; blocking this binary breaks the kill chain.
- Audit O365 mailbox delegation rules monthly — post-spray, APT33 establishes persistent mailbox access via delegated permissions that survive password resets.
- Deploy SHAPESHIFT/DistTrack wiper detections as priority — the destructive capability means this group's espionage access could escalate to sabotage at any time.
- Monitor for new O365 OAuth app registrations and third-party consent grants — APT33 abuses app permissions for persistent cloud access post-credential compromise.

12. References

- [1] MITRE ATT&CK. "APT33 — G0064." <https://attack.mitre.org/groups/G0064/>
- [2] Mandiant. "APT33: Insights into Iranian Cyber Espionage." <https://www.mandiant.com/resources/apt33-insights-into-iranian-cyber-espionage>
- [3] Microsoft Threat Intelligence. "Peach Sandstorm password spray attacks." <https://www.microsoft.com/security/blog/>

- [4] Huntress. "Refined Kitten (APT33) Threat Actor Profile." <https://www.huntress.com/threat-library/threat-actors/refined-kitten-apt33>
- [5] Anvilogic. "APT33 Targets Aerospace to Oil with Password Spraying." <https://www.anvilogic.com/threat-reports/apt33-attacks-and-azure>
- [6] CISA. Nation-State Advisories — Iran. <https://www.cisa.gov/topics/cyber-threats-and-advisories/nation-state-cyber-actors>